

Syllabus : Exploitation des grands modèles linguistiques (LLM) pour la détection de vulnérabilités en Cybersécurité

Auteur : Badr TAJINI - LLM pour la détection de vulnérabilités en Cybersécurité - ECE - 2025/2026

CREDITS ECTS : X

NOMBRE D'HEURES DISPENSEES : 16H

COURS MAGISTRAUX	TRAVAUX DIRIGES	TRAVAUX PRATIQUES	PROJETS
8	8	0	0

NOMBRE D'HEURES DE TRAVAIL PERSONNEL : ~20h pour le projet final

MODALITE PEDAGOGIQUE : PRESENTIEL

LANGUE : FRANÇAIS / ANGLAIS (interactions LLM et ressources souvent en anglais)

Objectifs

- Les objectifs du cours sont les suivants :
 - Comprendre le rôle et le potentiel des LLM en cybersécurité.
 - Maîtriser les concepts fondamentaux des LLM pertinents pour la sécurité.
 - Développer des compétences en ingénierie des prompts pour la détection de vulnérabilités.
 - Appliquer les LLM à l'analyse de code source et de configurations pour identifier des failles potentielles.
 - Évaluer de manière critique les résultats des LLM et comprendre leurs limites intrinsèques.
 - Utiliser les LLM de manière éthique et responsable dans un contexte de sécurité (confidentialité, biais).

Prérequis

- Connaissances fondamentales en cybersécurité (types de vulnérabilités communes, ex: OWASP Top 10).
- Concepts de base en programmation / scripting (lecture et compréhension de code - ex: Python, JavaScript, Java).
- Intérêt pour l'intelligence artificielle et ses applications en sécurité.

Contenu

Le cours comprend les séances théoriques suivantes (8 modules d'environ 1h) :

1. Module 1 : Introduction - IA & LLM dans le paysage de la cybersécurité
2. Module 2 : Fondamentaux des LLM pour les ingénieurs en cybersécurité
3. Module 3 : L'Art de l'ingénierie des prompts pour la détection de vulnérabilités

4. Module 4 : Application des LLM à l'analyse de code source (Amélioration SAST) 5. Module 5 : LLM pour la revue de configurations & la sécurité IaC (Infrastructure as Code) 6. Module 6 : Au-delà du code & des configurations - autres applications potentielles 7. Module 7 : Évaluation des résultats des LLM & l'impératif de l'humain dans la boucle 8. Module 8 : Limitations, risques de sécurité liés aux LLM, et tendances futures

*Note : Les 8h de mini-projets (4 mini-projets * 2h) seront consacrées à la mise en pratique de ces concepts (prise en main des LLM, prompting pour code/config, analyse critique).*

Compétences à acquérir

1. Expliquer les capacités et les limitations des LLM pour les tâches d'analyse de sécurité.
2. Formuler des prompts (requêtes) clairs, spécifiques et contextuels pour interroger efficacement un LLM sur des questions de cybersécurité.
3. Utiliser un LLM comme assistant pour identifier des vulnérabilités potentielles dans des extraits de code (ex: Python, JavaScript, Java).
4. Utiliser un LLM pour rechercher des erreurs de configuration courantes dans des fichiers de configuration (ex: SSH, Nginx, politiques Cloud).
5. Analyser de manière critique et vérifier les suggestions de sécurité ou les vulnérabilités signalées par un LLM.
6. Comprendre les risques liés à la confidentialité des données lors de l'utilisation de LLM avec du code ou des configurations sensibles.
7. Rédiger un rapport de revue de sécurité succinct basé sur les résultats d'un LLM, incluant une analyse humaine critique.

Modalités d'évaluation

- Contrôle Continu (mini-projets notés) - **50%**
- Projet Final (Réalisation d'une revue de sécurité assistée par LLM sur un artefact fourni, avec rapport détaillé - analyser/critiquer des interactions LLM) - **50%**

Références bibliographiques :

- [1] **Pearce, H., Ahmad, B., Tan, B., Dolan-Gavitt, B., & Karri, R. (2022).** *Asleep at the Keyboard? Assessing the Security of GitHub Copilot's Code Contributions.* In IEEE Symposium on Security and Privacy (SP) 2022.
- [2] **Noever, D. (2023).** *Can Large Language Models Find And Fix Vulnerabilities? A Case Study on GitHub Copilot.* arXiv preprint arXiv:2304.01467.
- [3] **Fu, T., Chen, J., Li, W., Wang, H., Jin, H., & Zhang, H. (2023).** *Does GPT-4 Pass the Bar Exam on Cybersecurity? Evaluating GPT-4's Security Capabilities.* arXiv preprint arXiv:2312.11341.
- [4] **Sobania, D., Briesch, M., Hanna, C., & Petke, J. (2023).** *An Analysis of the Automatic Bug Fixing Performance of ChatGPT.* arXiv preprint arXiv:2301.08653.
- [5] **Schuster, E., Adolphs, L., Lammich, P., & Neumann, G. (2023).** *Can we trust LLMs? An Assessment of Code Generation Capabilities of ChatGPT.* arXiv preprint arXiv:2307.08164.
- [6] **Fischer, M., Zipf, S., & Krombholz, K. (2024).** *Large Language Models for Vulnerability Detection: A Systematic Literature Review.* arXiv preprint arXiv:2402.15416.

- [7] **Oliyunkov, R. (2023).** *Large Language Models for Source Code Analysis*. Vector Institute.
- [8] **Perry, N., Simko, M., & Aharoni, M. (2023).** *Security Implications of Large Language Models*. IBM Research.
- [9] **Happe, A., & Siemens Cybersecurity Team. (2023).** *Using Large Language Models (LLMs) for cybersecurity: perspectives, benefits, and risks*. Siemens Whitepaper.
- [10] **Kang, D., Li, X., Sims, C., Appel, A. W., & Wang, T. (2023).** *Exploring the Security Vulnerabilities of Large Language Models*. arXiv preprint arXiv:2311.12513.
- [11] **Jones, N. (2023).** *How AI is shaking up code generation — and cybersecurity*. Nature News Feature.
- [12] **Dakhel, A. M., Rauf, U., Eltanbouly, S., Malik, H., & Nandi, A. (2023).** *Leveraging Large Language Models for Automated Unit Test Generation and Vulnerability Detection*. In Proceedings of the 2023 ACM/IEEE International Conference on Automation of Software Test (AST).

Ressources supplémentaires :

- **OWASP Top 10 for Large Language Model Applications:** Projet OWASP dédié aux risques spécifiques des applications basées sur les LLM. Utile pour comprendre les vecteurs d'attaque contre les LLM eux-mêmes. (<https://owasp.org/www-project-top-10-for-large-language-model-applications/>)
- **Blogs Techniques des Fournisseurs de LLM (OpenAI, Google AI, Anthropic) et Entreprises de Sécurité (NCC Group, Trail of Bits, Synack, etc.) :** Publient souvent des articles sur les capacités, limitations et utilisations sécuritaires de leurs modèles ou des LLM en général.